

Security Concept Summary

Cloud Security 1 — Criterion 1: Cloud Security Fundamentals & Shared Responsibility

Care Access Navigator | IAM + GRC Healthcare Cybersecurity Capstone | Prepared 09/16/2026

1. Purpose

This document defines the security concept and data classification model for the cloud storage component built to satisfy the Cloud Security 1 course rubric. The Azure Blob Storage container **cloudsec1-evidence** (in storage account **cloudsecevidencen**) is a cloud-hosted extension of Care Access Navigator's existing GRC/Reporting evidence index, holding screenshots, configuration exports, and logs generated while completing this rubric. It does not replace the project's on-premises evidence store — it supplements it with cloud-native evidence.

2. Data Classification Tiers — Applied to Care Access Navigator

All data associated with the capstone, whether stored on-prem or in Azure, is classified into one of four tiers below. Rather than generic examples, each row maps to the actual data types already defined in the Project Design Documentation (Sections 5–6): synthetic identities, RBAC role definitions, authentication/SIEM logs, the risk register/control matrix/evidence index, and the synthetic patient records held by the EHR Simulator and Patient Portal applications.

Tier	Care Access Navigator data	Required handling
Public	Sanitized architecture/workflow diagrams (Lucidchart), the Project Design Documentation once cleaned for portfolio use, 5-minute demo materials	No restriction
Internal	Monday.com board content, non-role-specific Keycloak realm settings, working drafts of docs before finalization	Access limited to the project team
Confidential	RBAC role/permission definitions and IAM policy exports; the risk register, control matrix, gap assessment, and evidence index; authentication/SIEM logs; incident response reports	Encrypted, access-logged
Restricted (simulated ePHI)	Synthetic patient records in the EHR Simulator/Patient Portal; Billing App and HR App fields resembling PHI/PII (synthetic SSNs, insurance IDs, diagnosis codes); access-log entries showing which specific record was touched	Encrypted, versioned, no public access. This is the tier held by cloudsec1-evidence.

3. Shared Responsibility Model

Cloud security responsibility is split between Microsoft and the project team differently depending on the service tier. The table below applies this to three real resources this project uses or will use, rather than generic IaaS/PaaS/SaaS examples.

Resource type	Example in this project	Microsoft's responsibility	Your responsibility
IaaS	An Azure VM hosting the EHR Simulator/Patient Portal stand-in (built in Criterion 2/3)	Physical datacenters, hypervisor, host hardware, network infrastructure	Guest OS patching, host firewall config, IAM roles attached to the VM, data on its disk
PaaS	Azure Functions (secured in Criterion 3) or Azure SQL Database for the EHR Simulator's data	Runtime, OS, scaling, platform patching	Function code, execution role/managed identity permissions, secrets, data stored in it
SaaS	Tableau or Monday.com — both already in the project's Tech Stack (Section 6)	Application security, hosting, uptime	Account credentials + MFA, what data is uploaded, who dashboards/boards are shared with

The IaaS and PaaS rows reference the actual VM and Function this project builds later in the rubric (not invented examples), and the SaaS row ties back to tools the capstone already committed to — so the table describes one coherent environment rather than three unrelated services.

4. Where This Fits in the Capstone Timeline

This classification scheme's primary home on the capstone's own 12-week milestone table is **Week 9 — Controls & Compliance Mapping**, where the project control inventory is mapped to HIPAA Security Rule and NIST framework concepts. Data classification is itself an administrative safeguard control, so this table is written to be reused directly as Week 9 evidence rather than rebuilt from scratch later.

It also supports two earlier weeks already in progress: **Week 3 — IAM Architecture & RBAC** (this tiering is the justification for why each of the seven roles gets the access level it does — a Clinician's job requires Restricted-tier access, a Vendor's normally doesn't), and it will support **Week 8 — GRC Risk Assessment**, since a risk like “excessive ePHI access” only makes sense as a risk because this table defines a Restricted tier that access shouldn't casually cross into.

Net effect: completing this table now, as part of the Cloud Security 1 rubric, puts Week 9 partly ahead of schedule — carry this exact table forward when that week arrives instead of redoing it.

5. Five-Risk Cloud Risk Assessment

Likelihood and Impact are scored 1 (Low) – 3 (High); Risk Score = Likelihood × Impact; Rating is 1–2 Low, 3–4 Medium, 6–9 High. The full version of this table, with data-validation dropdowns and live formulas, is delivered separately as Care_Access_Navigator_Cloud_Risk_Assessment.xlsx so these rows can be appended directly into the project's actual risk register.

ID	Risk	Category	L	I	Score	Rating	Mitigation / Control	Status
CR-01	Storage account/container misconfigured to allow public read access	Data Exposure	1	3	3	Medium	Block Public Access enforced on cloudsec1-evidence; Azure Policy alert on access-level change	Mitigated
CR-02	Over-permissive Entra ID / IAM role assignment	Access Control	2	3	6	High	Least-privilege custom policies per RBAC role; periodic access review (capstone Week 4)	Planned
CR-03	Unpatched Azure VM hosting the EHR Simulator/Patient Portal stand-in	Infrastructure	2	2	4	Medium	Automated patching (Azure Update Manager); host firewall in addition to NSG	Planned
CR-04	Vulnerable base image in the containerized EHR Simulator/Patient Portal app	Application Security	2	2	4	Medium	Trivy scan before deploy; pinned, minimal base image versions	Planned
CR-05	Entra ID user/service account without MFA enabled	Identity	2	3	6	High	MFA enforced via Conditional Access policy tenant-wide	Planned

6. Statement of Scope

This project uses synthetic, non-production data only. No real patient information, protected health information (PHI), or production healthcare data is ever stored in this Azure environment, encrypted or otherwise. This is consistent with the synthetic-data methodology already established across the rest of the Care Access Navigator capstone.

Evidence on file: screenshots of the container's Anonymous Access Level (Private), soft-delete/versioning settings, and the storage account's default encryption configuration (Microsoft-managed keys).